



GÜLTIG FÜR DIE ALPHA-REIHE

ASTRAEAOS WP

HANDBUCH & SYSTEMARCHITEKTUR

Funktionsweise, Sicherheitsmodell, Module und Betrieb

WORDPRESS WITHOUT THE PLUGIN STACK

First-Party Infrastruktur • Security by Design • Privacy by Default • Recovery First

AstraeaOS WP – Handbuch & Systemarchitektur

Gültig für die gesamte Alpha-Reihe

DOKUMENTSTATUS

Dieses Handbuch beschreibt die Architektur, Bedienlogik und Kernfunktionen der AstraeaOS-WP Alpha-Reihe. Einzelne Alpha-Builds können Funktionen erweitern, umbenennen oder härten. Das Dokument ist deshalb bewusst nicht an eine konkrete Astraea-Versionsnummer gebunden.

AstraeaOS WP ist eine sicherheitszentrierte WordPress-Distribution und ein Fork auf Basis von WordPress 7.1 (de_DE). Die Leitidee lautet „WordPress without the Plugin Stack“: universelle Infrastrukturaufgaben werden als First-Party-Subsysteme in den Astraea-Kernel integriert, während spezialisierte Fachanwendungen weiterhin über Plugins abgebildet werden.

Dieses Handbuch richtet sich an Administratoren, Entwickler, Sicherheitsprüfer und technische Entscheider. Es erklärt nicht jede einzelne PHP-Klasse, sondern verbindet die Benutzerperspektive mit den wichtigsten technischen Architekturentscheidungen aus der internen ARCHITECTURE.md.

ALPHA-HINWEIS

Die Alpha-Reihe ist Entwicklungssoftware. Sie ist für Test-, Staging- und kontrollierte Evaluationsumgebungen gedacht. Sicherheitsmechanismen reduzieren Risiken, ersetzen aber weder korrektes Server-Hardening noch Backups außerhalb des Systems, Monitoring und verantwortungsvolle Administration.

Inhalt

- Was AstraeaOS WP ist und warum es existiert
- Architektur und Bootmodell
- Secure Genesis – Installation mit Sicherheitsplan
- Astraea Module Fabric
- Sicherheitsmodell: GeDefense, ThroneGuard, Crypto und Step-Up
- Vault, Update Guard und autonome Recovery
- VLP Light und Dattrack
- Astraea Mail Gateway
- Performance Engine und Media Engine
- Web-Infrastruktur: Redirects, SEO, Forms, Tasks, Datenbank, Maintenance und Identity
- Update Engine, Migration und Compatibility Layer
- Admin UI und Mission Control
- Datenflüsse und Trust Boundaries
- Betriebshandbuch und empfohlene Abläufe
- Plugin-Strategie und Alpha-Gültigkeit
- Schnellreferenz und Glossar

01 Was AstraeaOS WP ist

AstraeaOS WP ist keine klassische WordPress-Installation mit einem großen Bündel vorinstallierter Plugins. Die Distribution übernimmt universelle Infrastrukturaufgaben direkt im eigenen Kernel. Dadurch teilen Security, Backup, Privacy, Mail, Recovery und weitere Module gemeinsame Dienste, gemeinsame Zustände und ein gemeinsames Sicherheitsmodell.

Leitidee: „WordPress without the Plugin Stack“

Bei einer gewöhnlichen WordPress-Seite wird die Basis häufig durch viele voneinander unabhängige Erweiterungen ergänzt: Firewall, Backup, Cookie-Banner, Analytics, SMTP, Cache, Bildoptimierung, Redirects, SEO, Formulare, Cron-Manager und Wartungsmodus. Jede dieser Erweiterungen bringt eigene Updatezyklen, Datenmodelle, Berechtigungslogik und potenziell zusätzliche Angriffsfläche mit.

Astraea verfolgt einen anderen Ansatz: Funktionen, die nahezu jede Website als Infrastruktur benötigt, werden First-Party in den Kernel integriert. Plugins bleiben weiterhin wichtig, aber vor allem für fachliche Spezialanwendungen wie Shops, LMS, Buchungssysteme oder branchenspezifische Integrationen.

Thema	Normales WordPress	AstraeaOS WP
Security	typisch über Drittanbieter-Plugin	GeDefense als Kernel-Subsystem
Backup / Rollback	Backup-Plugin	Astraea Vault + Recovery Gate
Consent / Analytics	Cookie- und Analytics-Plugins	VLP Light + Dattrack
Mail	SMTP-Plugin	Astraea Mail Gateway
Performance	Cache-/Optimierungsplugins	Performance Engine
Uploads / Medien	je nach Plugin	Media Engine + FileGuard
Updates	Upstream-WordPress-Core	eigene Update Engine + Core Update Guard
UI	klassisches wp-admin	Astraea Glass Shell + Mission Control

Was AstraeaOS WP ausdrücklich nicht sein soll

- **Kein Page-Builder-Ersatz.** Gutenberg bleibt die zentrale Content-Editing-Basis.
- **Kein Allzweck-Monolith.** Spezialisierte Fachfunktionen sollen modular bleiben.
- **Kein „100 % sicher“-Versprechen.** Sicherheitszustände müssen evidenzbasiert gemessen werden.
- **Keine Dependency-Sammlung.** Core und AdminUI vermeiden Composer-, npm- und CDN- Runtime-Abhängigkeiten.

02 Architektur und Bootmodell

Astraea verändert den Upstream-WordPress-Core möglichst chirurgisch. Die eigentliche Funktionalität lebt unter `astraea-core/`. Die Architektur nutzt wenige definierte Hook-Punkte in WordPress, um Security und Recovery zu Zeitpunkten auszuführen, die gewöhnlichen Plugins nicht zur Verfügung stehen.

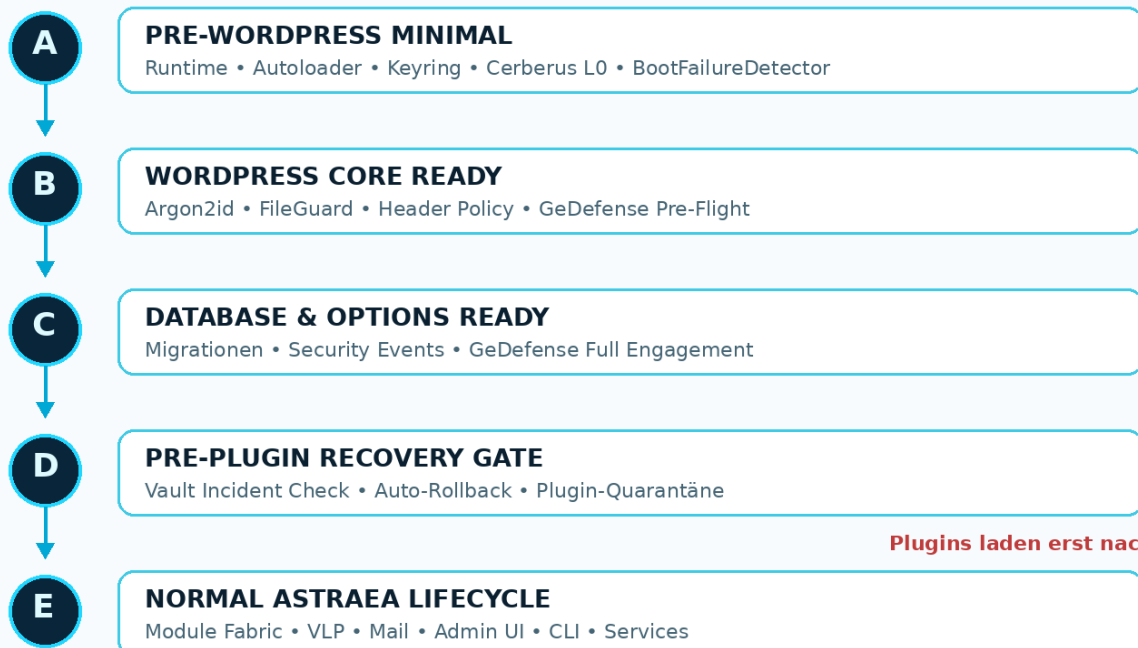
AstraeaOS WP - Architektur in Schichten



Abbildung: Schichtenmodell der AstraeaOS-WP Alpha-Reihe.

Die fünf Bootphasen

Deterministische Bootsequenz



Plugins laden erst nach Phase D

Abbildung: Security und Recovery werden bewusst vor dem regulären Plugin-Lifecycle verankert.

Phase	Zeitpunkt	Wesentliche Aufgaben
A	vor WordPress-Funktionen	Runtime Check, Autoloader, Keyring, Cerberus L0, BootFailureDetector
B	WordPress-Core verfügbar	Argon2id Overrides, Password Migration, FileGuard, Header Policy, GeDefense Pre-Flight
C	Datenbank & Optionen verfügbar	Schema-Migrationen, Security Events, GeDefense Full Engagement
D	vor MU-/Netzwerk-/normalen Plugins	Vault Incident Check, Auto-Rollback, Quarantäne
E	normaler Lifecycle	Module Fabric, VLP, Mail, Performance, UI, CLI und erweiterte Dienste

WARUM PHASE D WICHTIG IST

Ein normales Backup-Plugin kann selbst ausfallen, wenn ein anderes Plugin den Bootvorgang vorher mit einem Fatal Error beendet. Astraea Vault sitzt deshalb vor dem regulären Plugin-Load und kann Recovery-Maßnahmen ausführen, bevor die problematische Erweiterung erneut geladen wird.

Shared Core Services

Die First-Party-Module sollen keine parallelen Inseln bilden. Gemeinsame Dienste werden zentral bereitgestellt:

- CryptoService und Keyring für verschlüsselte Daten und Key-Rotation
- StepUpAuthService für sensible Administratoraktionen
- SecurityEventManager / SecurityEventBridge für evidenzbasierte Ereignisse
- AtomicCounter für race-resistentes Rate-Limiting
- Random/CSPRNG für Tokens, Salze und Schlüssel
- ModuleRegistry und ModuleDependencyGraph für Modulzustände und Abhängigkeiten
- BootFailureDetector für Crash-Loop-Schutz

03 Secure Genesis – Installation mit Sicherheitsplan

Der Astraea-Installer ist nicht nur ein visuelles Redesign des WordPress-Setups. Nach dem eigentlichen WordPress-Installationskern übernimmt Secure Genesis die Kontrolle und kompiliert eine definierte Sicherheitsbasis. Ziel ist, Schutzmechanismen bereits vor dem ersten regulären Login konsistent zu konfigurieren.

Installationsablauf

Schritt	Zweck
1. System Preflight	PHP, 64-Bit, Sodium, OpenSSL, Argon2id,

Schritt	Zweck
	Datenbankversion, HTTPS und Laufzeitbedingungen prüfen
2. Database & Core	Datenbank anbinden, Präfix und Baseline vorbereiten
3. Site Identity	Seitentitel, Sprache, Zeitzone und Basisdaten
4. Astraea Master	ersten privilegierten Master-Account einrichten
5. Security Profile	Balanced, Hardened, Maximum oder Custom wählen
6. ThroneGuard	Privilege Boundary und Recovery-Key provisionieren
7. GeDefense Matrix	Security-Module und Policies kompilieren
8. Network / Privacy / Communication	Netzwerkoberfläche, VLP und optional Mail vorbereiten
9. Security Compilation	Konfiguration anwenden und reale Probes ausführen
10. Verified Launch	Installationszustand auf READY setzen und in den ersten Runtime-Boot übergeben

Master- und Recovery-Modell

ThroneGuard trennt die besonders privilegierte Master-Rolle von gewöhnlichen Administratorrechten. Secure Genesis generiert einen hochentropischen Recovery-Key, der nur einmal angezeigt werden soll. Persistiert wird ausschließlich ein Argon2id-Verifier, nicht der Recovery-Key im Klartext.

BETRIEBSPFLICHT

Der Recovery-Key muss außerhalb der WordPress-Installation sicher aufbewahrt werden. Wer ihn verliert, darf nicht davon ausgehen, dass Astraea eine versteckte Hersteller-Backdoor besitzt.

Transaktionaler Installationsstatus

```

CORE_INSTALLED
↓
SECURITY_APPLYING
↓
SECURITY_VERIFYING
↓
READY

```

Fehlerpfad: SECURITY_FAILED / Resume

Damit ist „WordPress wurde installiert“ nicht automatisch gleichbedeutend mit „Astraea ist sicherheitsseitig fertig“. Ein unterbrochener Security-Compile-Pass soll resumierbar sein und nicht als erfolgreiche Installation erscheinen.

04 Astraea Module Fabric

Die Module Fabric ist die zentrale Lifecycle- und Abhängigkeitssteuerung für die First-Party-Subsysteme. Module besitzen Identität, Version, Bootphase, Abhängigkeiten, Zustände und Health-Probes. Eine Abhängigkeit wird nicht nur dokumentiert, sondern in einem gerichteten azyklischen Graphen aufgelöst.

Modul	Kernaufgabe	Typischer Boot
Recovery Gate	Crash-Loop-Erkennung, Notfallkonsole	Phase A
GeDefense	WAF, Perimeter, XDR, ThroneGuard	Phase C
Vault	Snapshots, Restore, Update Guard	Phase D
VLP Light	Consent, Gatekeeper, Dattrack	Phase E
Mail Gateway	SMTP, StrictTLS, XOAUTH2	Phase E
Performance	Page Cache, Browser Policy, Profiling	Phase E
Media	Upload-Sicherheit, SVG, Formate	Phase E
Redirects	301/302, Slug-Watcher, 404 Monitor	Phase E
SEO	Canonicals, OpenGraph, JSON-LD	Phase E
Forms	sichere Formulare, AEAD Storage	Phase E
Tasks	WP-Cron Inspektion und Trigger	Phase E
Database	Dry-Run Cleanup + Vault Snapshot	Phase E
Maintenance	HTTP-503 Wartungsmodus	Phase E
Identity	Sessions, Login Audit, Passwortstatus	Phase E
Update	signierte Astraea-Core-Updates	Phase E
Compatibility	granulare Ausnahmen	Phase E
Migration	Umstieg von Legacy-Plugin-Stacks	Phase E

Modulzustände

REGISTERED → BOOTING → ACTIVE
 ↳ DEGRADED
 ↳ FAILED
 DISABLED / BLOCKED je nach Konfiguration oder Dependency-State

Health-Probes sollen echte Evidenz liefern. Kann ein Zustand nicht geprüft werden, ist UNKNOWN oder DEGRADED korrekter als ein erfundenes HEALTHY.

05 Sicherheitsmodell: GeDefense, ThroneGuard, Crypto und Step-Up

Defense in Depth

Astraea verteilt Security bewusst auf mehrere Schichten. Ein einzelner Filter soll nicht die gesamte Schutzwirkung tragen. GeDefense kombiniert frühe Netzwerk-/IP-Entscheidungen mit WAF-/DPI-Logik, Browser-Confinement, RASP-nahen Kontrollen und XDR-Korrelation.

Komponente	Rolle
Cerberus	früher IP-/Perimeter-Drop vor komplexer PHP-Logik
Zeus	Vor-Boot WAF / Request-Normalisierung
Aegis	Deep Packet Inspection für typische Webangriffsmuster
Titan	Security Header und CSP Policy
Hades	optionale Login-/Admin-Tarnung und Mimikry
ThroneGuard	Master-Rolle, Privilege Separation, Recovery Key
Styx	Egress-/SSRF-Kontrollen
Morpheus	RASP-/Sandbox-nahe Schutzmechanismen
Gorgon	Telemetrie-/Rule-Sync innerhalb definierter Policies
Scanner	Datei-Triage: MALWARE, SUSPICIOUS, POLICY, INFO
TRINITY XDR	Korrelation einzelner Events zu Incidents

ThroneGuard: Administrator ist nicht automatisch Master

Die Master-Rolle soll verhindern, dass jede gewöhnliche Administrator-Session automatisch dieselbe Kontrolle über kritische Sicherheitsfunktionen erhält. Besonders sensible Operationen werden zusätzlich durch Step-Up geschützt.

Session-gebundene Step-Up-Authentifizierung

Sensible Aktionen verlangen eine frische Re-Authentifizierung innerhalb der aktuellen Browser-Sitzung. Die Verifikation ist an den WordPress-Session-Token gebunden und typischerweise zeitlich begrenzt. Beispiele sind Restore, Snapshot-Löschung, Modul-Toggles, SMTP-Secrets, Datenbankbereinigung und VLP-Registry-Änderungen.

Kryptografisches Fundament

Astraea verwendet zentrale AEAD-Dienste statt je Modul eigene Verschlüsselungslösungen zu bauen. Das Architekturmodell sieht Libsodium XChaCha20-Poly1305 und AES-256-GCM vor. Schlüssel werden versioniert und besitzen Lifecycle-Zustände wie ACTIVE, DECRYPT_ONLY, RETIRED und REVOKED.

HKDF-Domain-Separation sorgt dafür, dass unterschiedliche Datenklassen nicht denselben kryptografischen Kontext verwenden. Beispiele sind MAIL_TRANSPORT, VLP_CONSENT, FORMS_SUBMISSION, VAULT_SNAPSHOT, DATTRACK_ANALYTICS und SECURE_OPTIONS.

WICHTIG

„Verschlüsselt gespeichert“ ist nur dann sinnvoll, wenn Schlüsselverwaltung, Rotation, Authentizitätsprüfung und Fehlerverhalten ebenso sauber sind. Astraea behandelt deshalb Keyring, Master Key, AAD und Fail-Closed-Verhalten als gemeinsame Plattformdienste.

06 Vault, Update Guard und autonome Recovery

Astraea Vault

Vault ist kein reines Backup-Archiv. Es ist Teil des Continuity- und Recovery-Modells. Snapshots werden streamingbasiert erstellt und in .avb-Containern abgelegt. Die Architektur nutzt Envelope Encryption: Backupdaten erhalten eigene Data Keys, die wiederum durch Passphrase- oder Service-Key-Mechanismen geschützt werden.

- vollständige oder gezielte Snapshots von Datenbank und Dateien
- AES-256-GCM Container-IO mit Integritätsprüfung
- VerifyService für Container- und SHA-256-Prüfungen
- Pre-Update Snapshots für Plugins, Themes und Astraea-Core
- Pre-Cleanup Snapshots vor Datenbankbereinigungen
- Rollback und Quarantäne bei kritischen Fehlern

Recovery Gate vor Plugins

```

Boot startet
↓
Phase D: Vault prüft Incident-/Crash-State
↓
Problem erkannt?
├─ Nein → Plugins laden
└─ Ja  → Rollback / Quarantäne / Recovery
  
```

Autonome Recovery-Konsole

Unter /astraea-recovery/ existiert ein eigener Notfallpfad, der möglichst wenig vom normalen WordPress-Lifecycle benötigt. Nach Recovery-Key-Authentifizierung können Administratoren im Notfall Plugins oder Module deaktivieren, Maintenance steuern, Boot-Zähler zurücksetzen und Diagnosezustände prüfen.

RECOVERY-PRINZIP

Das Recovery-Subsystem soll nicht davon abhängig sein, dass genau die Komponenten funktionieren, die möglicherweise gerade den normalen Boot blockieren.

07 VLP Light und Dattrack

Consent als Kernel-Funktion

VLP Light (VisionLegalPro Light Edition) integriert Consent-Management und Privacy-Gating direkt in Astraeea. Das Ziel ist, externe oder nicht notwendige Ressourcen vor Einwilligung zu blockieren und die Service Registry zentral verwaltbar zu machen.

- serverseitiges Gate über WP_HTML_Tag_Processor
- clientseitiges DOM-/Property-Gate für dynamisch eingefügte Ressourcen
- HMAC-authentifizierte Consent-Receipts im HttpOnly Cookie
- editierbare Service Registry und Scanner für externe Ressourcen
- Privacy-Center im Astraeea-Glass-Design

Dattrack Light

Dattrack ist die integrierte, self-hosted Analytics-Schicht. Es wird nur innerhalb der vorgesehenen Consent-Logik aktiv. Die Architektur vermeidet Raw-IP-Langzeitspeicherung, nutzt rotierende pseudonyme Identifier und verschlüsselt Analytics-Payloads über den Astraeea-Crypto-Kontext.

RECHTLICHER HINWEIS

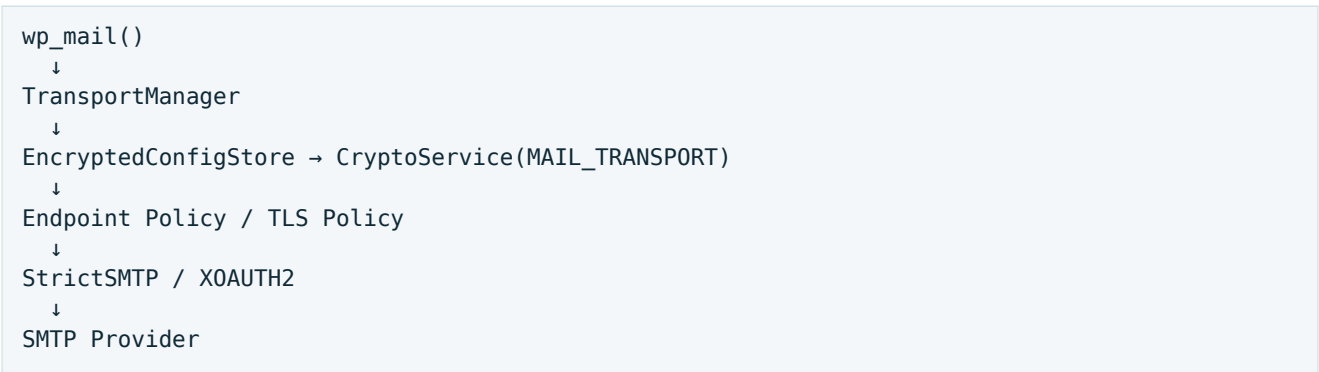
Technische Privacy-by-Design-Maßnahmen sind keine pauschale Rechtsberatung oder automatische Garantie für DSGVO-Konformität. Verantwortliche müssen Zwecke, Rechtsgrundlagen, Texte und lokale Anforderungen selbst prüfen.

08 Astraeea Mail Gateway

Das Mail Gateway ersetzt für viele Installationen ein separates SMTP-Plugin. Es integriert sich in den vorhandenen WordPress-Mailpfad, erzwingt aber Astraeea-eigene Transport- und Secret-Policies.

Bereich	Umsetzung
Provider	Presets für verbreitete Anbieter plus Custom SMTP
Transport	STARTTLS / SMTPS mit StrictTLS
TLS	TLS 1.2/1.3, Zertifikats- und Hostprüfung
Modern Auth	XOAUTH2 ohne zusätzliche OAuth-Library
Secrets	AEAD-verschlüsselte Profile / Tokens / Secrets
SSRF	Endpoint-Policies gegen Loopback, private Netze und Metadata-Ziele
Diagnose	SMTP Probe und Transportstatus
Journal	nur minimale Zustellmetadaten, keine Mailinhalte

Typischer Datenfluss



Credential-Änderungen und Testaktionen sollen Step-Up-geschützt sein. Die Compatibility Layer kann Ausnahmen zulassen, sollte aber nur als minimal wirksame, auditable Ausnahme verwendet werden.

09 Performance Engine und Media Engine

Performance Engine

Die Performance Engine soll typische Cache- und Optimierungsplugins für Standard-Websites ersetzen, ohne historische „alles zusammenführen und minifizieren“-Heuristiken blind zu übernehmen.

- Disk-Page-Cache mit atomaren Writes und Invalidierung
- Consent-aware Cache-Varianz für VLP-Zustände
- Browser-Cache-Policies und immutable für versionierte Assets
- Heartbeat-Steuerung
- Autoload-Profiling und Budgets
- Legacy-Pruner für nicht benötigte WordPress-Oberflächen wie XML-RPC/Pingbacks nach Policy
- Request- und Datenbankprofiling im Mission Control

Media Engine

Die Media Engine verschiebt Upload-Sicherheit in eine definierte Pipeline: Dateityp nicht nach Browser-MIME vertrauen, Magic Bytes prüfen, aktive Inhalte behandeln, Metadaten kontrollieren und moderne Formate nur dann anbieten, wenn der Server sie tatsächlich unterstützt.

Funktion	Schutz / Nutzen
Magic-Byte-Prüfung	erschwert Extension- und MIME-Spoofing
SVG Sanitization	beschränkt aktive XML/SVG-Konstrukte
EXIF Policy	kann GPS- und Kamerametadaten entfernen
GD Re-Encode	normalisiert unterstützte Rasterbilder
WebP / AVIF Capability	nur aktiv, wenn serverseitig verfügbar

10 Weitere Web-Infrastrukturmodule

Redirect Manager

Verwaltet 301/302-Weiterleitungen, beobachtet Slug-Änderungen und bietet 404-Telemetrie. Regex-Regeln sind begrenzt, Redirect-Loops und Ketten werden geprüft. Datenschutzfreundliches Monitoring soll keine unnötigen Roh-IP-Daten persistieren.

SEO Essentials

Astraea integriert die technischen SEO-Grundlagen, nicht die typische „Ampel“- oder Keyword-Bewertung. Enthalten sind Canonicals, Meta-Descriptions, OpenGraph/Twitter-Cards, JSON-LD und Sitemap-Erweiterungen. Bei bekannten externen SEO-Plugins soll ConflictDetector doppelte Ausgabe vermeiden.

Forms Light

Forms Light deckt Standardformulare mit sicherer Submission-Pipeline ab. CSRF-Schutz, Honeypot, atomisches Rate-Limiting, Upload-Prüfungen und optionale verschlüsselte Speicherung teilen sich vorhandene Astraea-Dienste.

```
Form Submit
↓
CSRF / Nonce
↓
GeDefense / Rate Limit / Honeypot
↓
Validation + Upload Pipeline
↓
CryptoService(FORMS_SUBMISSION) optional
↓
Mail Gateway optional
```

Task Center

Das Task Center macht WP-Cron sichtbar: geplante Hooks, Quelle, nächste Ausführung, überfällige Tasks und ungewöhnlich hohe Frequenzen. Manuelle Trigger sind auf validierte, tatsächlich geplante Hooks begrenzt.

Database Maintenance

Database Maintenance arbeitet nach dem Muster Analyze → Dry Run → Vault Snapshot → Step-Up → Cleanup. Bereinigt werden können etwa Revisionen, Spam, Papierkorb, abgelaufene Transients und ausgewählte verwaiste Daten. Kann kein Snapshot erstellt werden, soll die destruktive Bereinigung fail-closed abbrechen.

Maintenance Mode

Der Wartungsmodus liefert einen SEO-sauberen HTTP-503-Status mit Retry-After, erlaubt Administrator- oder Token-Bypass und rendert eine lokale Glassmorphism-Seite ohne CDN-Abhängigkeit.

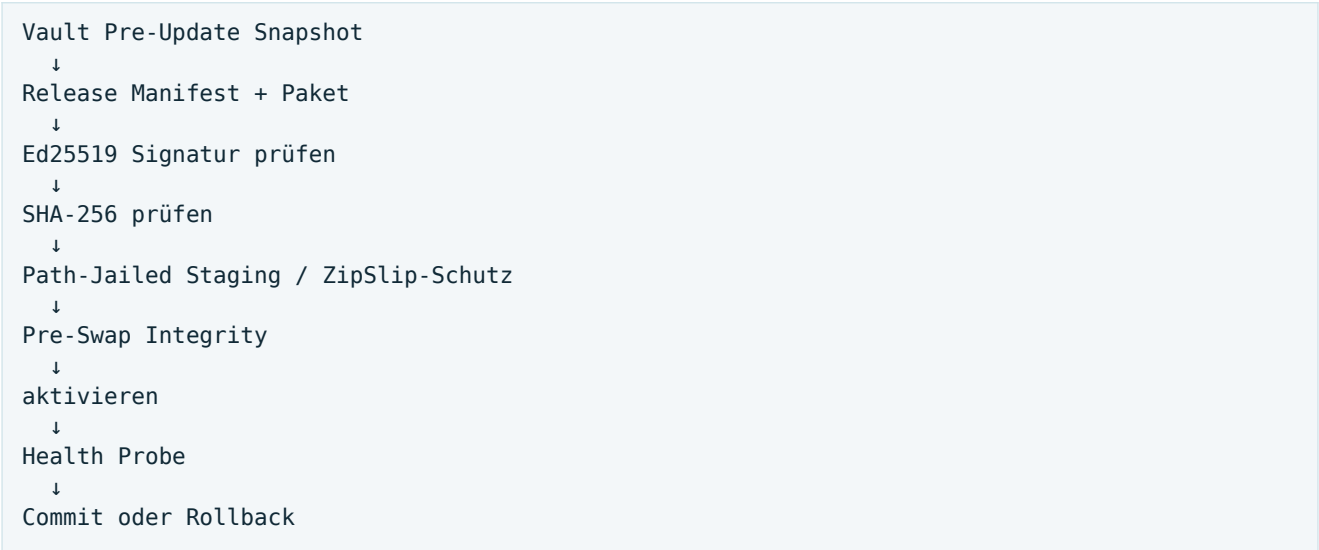
Identity Center

Das Identity Center zeigt aktive Sitzungen, Login-Auditdaten und Passwortstatus. Fremde Sessions können gezielt beendet werden. Funktionen wie Passkeys/WebAuthn sollen nur dann als implementiert erscheinen, wenn der tatsächliche Authentifizierungsflow vollständig vorhanden ist.

11 Update Engine, Migration und Compatibility Layer

Astraea Update Engine

Da Astraea ein WordPress-Fork ist, darf ein normaler Upstream-Core-Updatepfad den Astraea-Kernel nicht überschreiben. Der Core Update Guard blockiert daher Standard-Core-Updates. Die eigene Update Engine ist für signierte Astraea-Distributionen ausgelegt.



Release-Authentizität ist getrennt von Dateintegrität zu betrachten: Ein SHA-256-Hash erkennt Änderungen, beweist aber ohne vertrauenswürdige Signatur nicht, dass das Paket tatsächlich von VisionGaiaTechnology stammt.

Migration Wizard

Der Migration Wizard analysiert bestehende WordPress-Installationen und erkennt Infrastruktur-Plugins, deren Aufgaben Astraea bereits nativ abdecken kann. Vor Änderungen wird ein Vault Snapshot verlangt. Plugins werden nicht automatisch gelöscht; die Migration ist auf zerstörungsfreie Deaktivierung und Rückkehrmöglichkeit ausgelegt.

Legacy-Kategorie	Astraea-Ziel
Security Plugin	GeDefense
Backup Plugin	Vault
Cookie/Consent	VLP Light
Analytics	Dattrack
SMTP	Mail Gateway

Legacy-Kategorie	Astraea-Ziel
Cache/Performance	Performance Engine
Redirects	Redirect Manager
Basis-SEO	SEO Essentials
Standardformulare	Forms Light

Compatibility Layer

Astraea versucht Kompatibilität nicht durch globales Abschalten von Security zu erkaufen. Stattdessen gilt das Prinzip der „minimalen effektiven Ausnahme“: nur die konkrete Funktion lockern, die ein Theme oder Plugin tatsächlich benötigt, die Ausnahme kennzeichnen und auditieren.

KOMPATIBILITÄT IST EIN TRADE-OFF

Flags wie Legacy-XMLRPC, relaxed REST auth oder PHP-Mail-Fallback können sinnvoll sein, reduzieren aber je nach Einsatz die ursprüngliche Astraea-Baseline. Sie sollten dokumentiert, begründet und regelmäßig überprüft werden.

12 Admin UI und Mission Control

Astraea legt über die WordPress-Administrationsbasis eine eigene, konsistente Glassmorphism-Shell. Ziel ist keine komplette Neuimplementierung des Backends, sondern ein einheitliches Interface über Core-Screens und First-Party-Module.

- Astraea Topbar und kategorisierte Sidebar
- NavigationAdapter mit Bereichen CONTENT, DESIGN, SYSTEM, ASTRAEA und EXTENSIONS
- Mission Control Dashboard mit Security- und Systemtelemetrie
- Command Palette über Ctrl+K
- Notice Center mit Toasts und Drawer
- Legacy Surface Adapter für klassische WordPress-Tabellen, Postboxes und Plugin-Oberflächen
- Glass Login Portal und Secure Genesis Installer

Designsystem

Die UI verwendet lokale Design Tokens für Farben, Abstände, Typografie und Schatten. Layer wie glass surface L1/L2/L3 definieren unterschiedliche Tiefen. Assets liegen lokal; es werden keine Google Fonts oder CDN-JavaScript-Bibliotheken benötigt.

UI-Bereich	Beispiel
Mission Control	Systemzustand, Security-HUD, Performance
GeDefense Suite	WAF, Scanner, XDR, Titan
Vault	Snapshots, Restore, Schlüsselaktionen
VLP Light	Consent, Services, Scanner, Dattrack
Mail Gateway	Provider, TLS, OAuth, Diagnose
Module Fabric	Aktivstatus, Dependencies, Health

UI-Bereich	Beispiel
Recovery	autarke Notfalloberfläche

13 Datenflüsse und Trust Boundaries

Öffentlicher Seitenaufruf

```

Browser Request
↓
Phase A/B Security Baseline
↓
Phase C GeDefense
↓
Phase D Recovery Gate
↓
Plugins / Theme
↓
Phase E Modules
↓
VLP / Performance / Headers
↓
Response

```

Privilegierte Administratoraktion

```

Admin klickt kritische Aktion
↓
Capability + Nonce
↓
Step-Up Session-Verifikation
↓
optionaler Vault Snapshot
↓
Operation
↓
Health / Security Event

```

Formularsubmission

Formulardaten bewegen sich durch CSRF-, Rate-Limit-, Validierungs-, Upload- und Crypto-Schichten. Sensible Payloads sollen nicht in generische Logs geschrieben werden. Die Verschlüsselung at rest nutzt einen eigenen Domain-Kontext.

API-Architektur

Astraea nutzt WordPress AJAX-, admin-post- und ausgewählte REST-Endpunkte. Administrative Mutationen werden mit Nonces, Capabilities und bei sensiblen Aktionen zusätzlich Step-Up gesichert. Öffentliche Endpunkte wie Consent, Dattrack oder CSP Reporting müssen eigene Rate-Limits und minimierte Payloads besitzen.

Dateisystem-Trust Boundary

Dateioperationen werden mit Path-Jails, realpath-Prüfungen, Symlink-Awareness und begrenzten Staging-Bereichen ausgelegt. Besonders Update, Vault, Media, Forms und Recovery sind Dateisystem-nahe Subsysteme und müssen Pfadgrenzen konsequent einhalten.

14 Betriebshandbuch

Nach der ersten Installation

- Recovery-Key offline sichern und Wiederherstellbarkeit organisatorisch dokumentieren.
- Mission Control öffnen und alle sicherheitskritischen Module auf ACTIVE/HEALTHY oder nachvollziehbare DEGRADED-Zustände prüfen.
- Vault konfigurieren und mindestens einen vollständigen Snapshot erzeugen und verifizieren.
- Mail Gateway konfigurieren und SMTP-Diagnose/Testversand durchführen.
- VLP Service Registry prüfen, Scanner ausführen und Consent-Texte fachlich/rechtlich kontrollieren.
- Performance Cache erst nach funktionaler Prüfung aktivieren bzw. für dynamische Bereiche ausnehmen.
- Compatibility Flags nur setzen, wenn ein konkretes Problem reproduzierbar ist.

Empfohlener Update-Ablauf

Schritt	Kontrolle
1	Release-Kanal und Signaturstatus prüfen
2	aktuellen Vault Snapshot verifizieren
3	Update nur über Astraea Update Engine anwenden
4	Health-Probes und Mission Control prüfen
5	Frontend, Login, Gutenberg, Formulare und Mail stichprobenartig testen
6	bei Fehlern Recovery/Last Known Good verwenden

Wenn eine Website nach Plugin-Update ausfällt

Nicht sofort Dateien manuell löschen. Zuerst Recovery Gate/Vault Incident State prüfen. Wenn Astraea das verantwortliche Plugin korrelieren kann, soll der Recovery-Mechanismus vor dem erneuten Plugin-Load einen kontrollierten Rollback oder eine Quarantäne ausführen.

Security Events triagieren

Ein Security Event ist Evidenz, nicht automatisch ein bestätigter Angriff. Besonders der Malware-Scanner unterscheidet MALWARE, SUSPICIOUS, POLICY und INFO. Nur weil eine Datei ungewöhnlich ist, darf sie nicht automatisch als Malware behandelt werden.

Klasse	Bedeutung
MALWARE	starke aktive Schadcode-Evidenz; blockierend/quarantärefähig

Klasse	Bedeutung
SUSPICIOUS	auffällig, aber nicht ausreichend für Malware-Behauptung
POLICY	verstößt gegen lokale Sicherheitsrichtlinie
INFO	Kontextinformation ohne Malware-Aussage

Backup-Disziplin

Astraea Vault reduziert Recovery-Risiken, ersetzt aber kein Offsite-Backup-Konzept. Für wichtige Systeme sollten verschlüsselte Snapshots regelmäßig zusätzlich außerhalb des Webservers aufbewahrt und Restore-Tests durchgeführt werden.

15 Plugin-Strategie und Gültigkeit der Alpha-Reihe

Welche Plugins Astraea typischerweise einsparen kann

Plugin-Kategorie	First-Party-Funktion
Security / WAF	GeDefense
Backup / Rollback	Vault
Cookie / Consent	VLP Light
Self-hosted Analytics	Dattrack Light
SMTP	Mail Gateway
Caching / Performance	Performance Engine
Bild-/Upload-Sicherheit	Media Engine
Redirects	Redirect Manager
technisches SEO	SEO Essentials
Kontakt-/Standardformulare	Forms Light
Cron Management	Task Center
DB Cleanup	Database Maintenance
Maintenance Plugin	Maintenance Mode
Session Security	Identity Center

Welche Funktionen weiter Plugins bleiben sollten

- WooCommerce und spezialisierter E-Commerce
- LMS / Kursplattformen
- Buchungs- und Reservierungssysteme
- CRM-/ERP-Fachlogik
- branchenspezifische Integrationen
- komplexe Page-Builder oder Designsysteme, sofern wirklich benötigt

Gültigkeit

GÜLTIG FÜR DIE ALPHA-REIHE

Dieses Handbuch trägt bewusst keine Astraea-Versionsnummer. Es beschreibt die gemeinsame Architektur- und Bedienphilosophie der Alpha-Reihe. Bei widersprüchlichen Details hat der tatsächlich installierte Build, dessen Release Notes und die aktuellen Health-/Compatibility-Hinweise Vorrang.

Die Alpha-Reihe kann intern stark weiterentwickelt werden. Besonders Update-, Recovery-, Performance-, Compatibility- und Security-Policies können sich durch Audits und Feldtests verändern. Das ist in dieser Entwicklungsphase gewollt.

16 Schnellreferenz und Glossar

Begriff	Bedeutung
AEAD	Authenticated Encryption with Associated Data; Verschlüsselung plus Integritäts-/Authentizitätsschutz
AAD	zusätzliche authentifizierte Kontextdaten, die nicht verschlüsselt werden müssen
Argon2id	passwortorientierte Key-/Hash-Funktion mit Memory Hardness
CSPRNG	kryptografisch sicherer Zufallszahlengenerator
GeDefense	Astraea Security Kernel aus Perimeter-, WAF-, XDR- und Identity-Komponenten
Keyring	versionierter Schlüsselbestand mit Lifecycle-Zuständen
Module Fabric	Registry, Dependency Graph und Lifecycle-Management der First-Party-Module
Recovery Gate	frühe Bootschrift vor Plugins zur Wiederherstellung
Step-Up	erneute Authentifizierung für kritische Aktionen
ThroneGuard	Master-Privilege-Separation und Recovery-Key-Modell
VLP Light	Privacy-/Consent-Kernel mit Dattrack
Vault	verschlüsselte Snapshot-, Restore- und Rollback-Engine
XDR	Korrelation und Reaktion über mehrere Security-Ereignisquellen
Zero External Dependencies	kein Composer/npm/CDN-Zwang für die Astraea Runtime

Wichtige Pfade

/astraea-core/ /astraea-recovery/ /wp-admin/	First-Party Kernel und Module autonome Notfallkonsole Upstream Admin + Astraea Surgical Hooks/UI
--	--

/wp-includes/	WordPress Baseline + Runtime-Anker
/wp-content/	Themes, Plugins, Uploads, Caches

Technische Grundlage

Die Systembeschreibung wurde aus der internen Architektur-Landkarte der Alpha-Reihe verdichtet. Die vollständige ARCHITECTURE.md enthält zusätzlich Dateireferenzen, API-Zuordnungen, Dashboard-Routen, Datenbanktabellen und detaillierte Komponentenbeziehungen.

VisionGaiaTechnology – AstraeaOS WP

AstraeaOS WP

One Kernel. One Security Model. One Recovery Model. One Privacy Model.

DOKUMENTENDE

Dieses Handbuch ist für die Alpha-Reihe gültig und soll mit der Architektur mitwachsen. Für produktive Entscheidungen sind immer der konkrete Build, aktuelle Release Notes, Tests und unabhängige Security Reviews maßgeblich.